NIYAMSAATHI COMPLIANCE ASSESSMENT PORTAL

TECHNICAL SPECIFICATION

Version 1.0 | September 2026

Prepared by: Aashray Infotech

CONFIDENTIAL — This document is provided for evaluation purposes as part of a commercial proposal. It is not to be distributed outside the recipient organization without written consent.

Table of Contents

1. Executive Summary
2. Regulatory & Framework Coverage
3. Product Overview
4. Functional Capabilities
5. Key Platform Workflows
    - 5.1 Organization Onboarding
    - 5.2 Data Asset Registration & Cloud Discovery
    - 5.3 Compliance Assessment Lifecycle
    - 5.4 Compliance Task & Evidence Review
    - 5.5 User Access Provisioning & Single Sign-On
    - 5.6 Workforce Compliance Training
6. User Roles & Access Model
7. Information Model
8. System Architecture
9. Technology Stack
10. Security & Data Protection
11. Integrations
12. Deployment & Hosting
13. Non-Functional Characteristics
14. Implementation Approach
15. Platform Roadmap
16. Glossary of Terms

1. Executive Summary

NiyamSaathi is a purpose-built compliance management platform that helps organizations operating in India meet their obligations under the Digital Personal Data Protection Act, 2023 (DPDP Act), alongside sector-specific regulations such as the RBI Data Localisation requirements and the SEBI Cybersecurity and Cyber Resilience Framework.

The platform gives organizations a single, structured workspace to inventory their data assets, assess and track risk, map regulatory controls to real systems and processes, run compliance assessments, manage evidence collection and internal audit review, and train their workforce — replacing the spreadsheets, email threads, and disconnected tools that most organizations currently rely on for compliance management.

NiyamSaathi is delivered as a cloud-hosted, multi-tenant SaaS platform, with each client organization operating in its own logically isolated workspace, and a platform console used by the operator to manage the regulatory control library, onboard new organizations, and maintain the platform.

2. Regulatory & Framework Coverage

NiyamSaathi's controls library is built around the following regulatory frameworks at launch:

- **Digital Personal Data Protection Act, 2023 (DPDP Act)** — the primary framework, covering data fiduciary obligations, data principal rights, consent and legal basis tracking, cross-border transfer conditions, and breach-related controls.
- **RBI Data Localisation requirements** — for organizations subject to Reserve Bank of India data storage and localisation directions.
- **SEBI Cybersecurity and Cyber Resilience Framework** — for organizations in the securities and capital markets ecosystem.

The controls library is centrally maintained and versioned by the platform operator, so client organizations automatically benefit from updates as regulatory guidance evolves, without needing to manage the control content themselves. The library architecture is designed to extend to additional regulations and frameworks over time without requiring structural rework of the platform.

3. Product Overview

NiyamSaathi consists of two applications, serving two distinct audiences:

3.1 Tenant Portal

The primary workspace used by a client organization to manage its own compliance program. Access within the Tenant Portal is role-based, giving each function within the organization — leadership, compliance, IT, and audit — a view and workflow suited to their responsibilities.

3.2 Platform Console

An operator-facing console used to onboard client organizations, maintain the shared regulatory controls library, manage the compliance training catalog, and monitor platform-wide activity. Client organizations do not have access to the Platform Console.

4. Functional Capabilities

4.1 Organization Onboarding

A guided setup workflow captures an organization's profile and Data Protection Officer details, its classification under the DPDP Act (Data Fiduciary or Significant Data Fiduciary), its organizational structure (departments, data assets, and key suppliers), and its initial team, with roles assigned at invitation. Organizations that use Microsoft Entra ID can connect it during setup for single sign-on and automated group-to-role mapping.

4.2 Data Asset & PII Register

A central, structured register of the organization's data assets — systems, applications, vendors, and processes — each classified by criticality, hosting location, internet exposure, and vendor relationship. Every asset carries a detailed personal data inventory: categories of personal data held, sensitivity level, legal basis for processing, purpose, retention period, deletion mechanism, data volume, cross-border transfer details, data principal type, and third-party sharing status.

Cloud Discovery. Organizations can connect their cloud environments — Amazon Web Services, Microsoft Azure, Google Cloud Platform, Microsoft 365, and Google Workspace — to automatically discover cloud resources and propose them as data assets, ready for a compliance owner to review and confirm into the register. This significantly reduces the manual effort of building

and maintaining an accurate asset inventory.

4.3 Risk Analysis

Risk heatmaps and a consolidated risk register give leadership and compliance teams a visual, prioritized view of exposure, derived from asset criticality, data sensitivity, and control status.

4.4 Controls Library

A pre-built library of controls mapped to the relevant chapters and sections of each applicable regulation, alongside the ability to define organization-specific custom controls — each with configurable applicability (Data Fiduciary, Significant Data Fiduciary, or both), linked action items, evidence requirements, priority, and due dates.

4.5 Compliance Assessments

Compliance Officers can scope and launch assessments against selected assets and controls, with live tracking of assets in scope, controls addressed, open action items, and time remaining in the assessment cycle.

4.6 Compliance Tasks & Evidence Workflow

Action items generated from assessments and controls are assigned to the relevant owner — typically IT — who submits evidence as a file, an external link, or a documented note. Evidence is version-controlled, preserving a complete history of every submission. An Internal Auditor reviews and approves or rejects each submission before it is considered compliant, and an External Auditor role provides independent, read-only visibility for third-party verification. Every step of this lifecycle is captured in the organization's audit trail.

4.7 Learning Management System

A compliance training catalog for the organization's workforce, with course progress tracking and completion certification, giving Compliance Officers visibility into training coverage across the organization.

4.8 Dashboards & Reporting

Each role sees a dashboard tailored to its responsibilities: executive risk and compliance posture for leadership, operational progress for Compliance Officers, task-focused views for IT, review queues and audit scheduling for Internal Auditors, and read-only summary reporting for External Auditors. Available report types include a Compliance Posture Summary, Risk Register export, Assessment Progress report, Evidence & Audit Trail export, and Training Completion report.

4.9 User & Access Management

Organization administrators manage user invitations, roles, and lifecycle from within the Tenant Portal, with support for Microsoft Entra ID single sign-on and automated group synchronization for organizations that use it.

4.10 Alerts & Notifications

An in-app notification feed keeps users informed of task assignments, approvals and rejections, and upcoming deadlines. Notifications are triggered by task assignment, evidence approval or rejection, tasks approaching or past their due date, assessments nearing their end date, and new team member invitations.

4.11 Audit Trail

Every compliance-relevant action within an organization's workspace is recorded in a complete, tamper-evident audit trail, with a separate platform-wide audit log maintained for operator-level activity.

5. Key Platform Workflows

This section describes how the platform's capabilities come together into complete, end-to-end processes.

5.1 Organization Onboarding

Step	Actor	Action	Outcome
1	Super Admin	Creates the organization record in the Platform Console and issues an invitation to the client's designated administrator.	Client administrator receives a secure setup link.
2	Compliance Officer (CO)	Sets a password and logs in for the first time.	Guided onboarding wizard launches.
3	CO	Completes the organization profile — legal name, industry, address, jurisdiction — and Data Protection Officer details.	Organization profile is stored.
4	CO	Selects the organization's DPDP classification: Data Fiduciary or Significant Data Fiduciary.	Classification determines which controls are activated as mandatory versus recommended.
5	CO	Defines the organizational structure — departments, key data assets, and supplier relationships — using the interactive structure builder.	Baseline department and asset records are created.
6	CO	Optionally connects Microsoft Entra ID and maps security groups to platform roles and departments.	Future user provisioning can be automated via group sync.
7	CO	Invites the initial team (CEO, IT Admin, Internal Auditor, External Auditor) with role and department assignment.	Invitees receive setup links; the organization moves from Onboarding to Active status.

5.2 Data Asset Registration & Cloud Discovery

Manual registration

Step	Actor	Action	Outcome
1	IT Admin / CO	Registers an asset through a guided form covering identity, ownership, technical details, and personal data inventory.	Asset record is created.
2	System	Validates required fields — for example, personal data details become mandatory once "Contains PII" is set.	Data quality is enforced at entry.
3	System	Publishes the asset to the register.	Asset is immediately available for control mapping and assessment scoping.

Automated Cloud Discovery

Step	Actor	Action	Outcome
1	IT Admin	Connects a cloud environment (AWS, Azure, GCP, Microsoft 365, or Google Workspace) using scoped credentials.	Connection is registered against the organization.
2	System	Validates the connection before accepting it.	Only working, authorized connections are retained.
3	IT Admin / CO	Triggers a discovery scan.	Scan job is queued and run in the background.
4	System	Scans the connected environment and matches discovered resources against the platform's resource-to-asset-type catalog.	A set of candidate assets is produced.
5	System	Presents discovered resources as draft assets for review — nothing is written to the live register automatically.	Human review checkpoint is preserved.
6	IT Admin / CO	Reviews each draft, adjusts classification if needed, and confirms or dismisses it.	Reviewer retains full control over what enters the official register.
7	System	Confirmed drafts become live assets, linked back to their source cloud connection for traceability.	Asset register stays current with materially less manual data entry.

5.3 Compliance Assessment Lifecycle

Step	Actor	Action	Outcome
1	CO	Defines an assessment: name, time window, in-scope assets, and applicable controls.	Assessment record is created.
2	System	Generates a compliance task for each relevant control-and-asset combination, assigned to the responsible owner with a due date and priority derived from the control definition.	Full task list is generated automatically — no manual task creation required.
3	System	Tracks assessment progress in real time: assets in scope, controls addressed, open tasks, days remaining.	CO and CEO have a live view of assessment health.
4	All roles	Each generated task proceeds through the Compliance Task & Evidence Review workflow (Section 5.4).	Tasks are resolved individually while rolling up to assessment-level progress.
5	CO	Monitors progress and can reassign or escalate tasks approaching their due date.	Bottlenecks are surfaced before deadlines are missed.
6	System	Marks the assessment Completed once all tasks are resolved, or Archived at the end of its cycle.	Assessment record is retained for historical reporting and audit.

5.4 Compliance Task & Evidence Review

This is the platform's core operational workflow — it governs how every compliance obligation is actually discharged and evidenced.

Task and evidence status progression

Status	Meaning
Pending	Task created and assigned; work not yet started.
In Progress	Task owner has begun work.
Evidence Submitted	Supporting evidence has been submitted for review.
Final Review	Evidence is with the Internal Auditor for decision.
Approved (Internal)	Evidence accepted; task considered compliant.
Rejected	Evidence did not meet requirements; returned to the task owner.
Overdue	Automatically applied to any unresolved task past its due date.

Workflow

Step	Actor	Action	Status Change
1	System	Task is created (from an assessment or directly from the Controls Library) and assigned to an owner.	→ Pending
2	IT Admin	Opens the task from "My Tasks" and begins work.	→ In Progress
3	IT Admin	Submits evidence — a file, an external link, or a documented note — with an optional comment.	→ Evidence Submitted
4	System	Stores the evidence with a version number, and links it to the task, asset, and control; the submission is recorded in the audit trail.	—
5	Internal Auditor	Opens the submission from the "Evidence Review" queue and evaluates it against the control's evidence requirements.	→ Final Review
6	Internal Auditor	Approves or rejects the submission, with a review comment.	→ Approved (Internal) or Rejected
7	System	Notifies the task owner of the outcome.	—
8	IT Admin	If rejected, revises and resubmits; the prior version is preserved in the evidence history, not overwritten.	→ Evidence Submitted (new version)
9	External Auditor	May independently view the task, its full evidence version history, and reviewer comments at any time, read-only.	—
10	System	Automatically flags any task past its due date without a resolved status, surfacing it on CO and CEO dashboards.	→ Overdue

5.5 User Access Provisioning & Single Sign-On

Manual invitation

Step	Actor	Action	Outcome
1	CO / Admin	Invites a user by email, assigning role and department.	Secure, time-limited invitation is sent.
2	User	Sets a password via the invitation link.	Account becomes Active.

Microsoft Entra ID group sync

Step	Actor	Action	Outcome
1	CO	Configures the Entra ID connection once, with credentials encrypted at rest.	Organization is linked to its Entra ID tenant.
2	CO	Maps specific Entra security groups to platform roles and departments.	Access rules are defined centrally, once.
3	User	Signs in with Microsoft.	Platform validates the identity token.
4	System	Reads the user's group membership and provisions or updates their role and department accordingly.	Access stays synchronized with the organization's own identity system, without manual re-assignment.

5.6 Workforce Compliance Training

Step	Actor	Action	Outcome
1	Super Admin	Publishes and maintains courses in the shared training catalog.	Catalog is available to client organizations.
2	CO	Assigns relevant courses to the organization's workforce.	Employees see assigned training in their LMS view.
3	Employee	Completes course content within the Tenant Portal.	Progress is tracked automatically.
4	System	Issues a completion certificate and updates the CO's training-coverage view.	Compliance training becomes auditable, not just delivered.

6. User Roles & Access Model

6.1 Role Definitions

Role	Scope
CEO	Executive oversight of organizational risk and compliance posture.
Compliance Officer (CO)	Organization setup, policy and control management, assessment scoping, task assignment.
IT Admin	Execution of technical controls, evidence submission, infrastructure and cloud connection configuration.
Internal Auditor	Review and approval of submitted evidence and compliance actions.
External Auditor	Read-only access for independent, third-party compliance verification.
Super Admin *(Platform Console)*	Onboarding of client organizations, maintenance of the shared controls library and training catalog, platform-wide monitoring.

6.2 Access Matrix (Tenant Portal)

Module	CEO	CO	IT Admin	Internal Auditor	External Auditor
Dashboard	View (executive)	View (operational)	View (task-focused)	View (review-focused)	View (summary)
Organization Setup	—	Full	—	—	—
Asset Register	View	Full	Manage	View	View
Cloud Connections	—	Manage	Full	View	—
Risk Analysis	View	Full	View	View	View
Controls Library	View	Full	View	View	View
Assessments	View	Full	View (assigned scope)	View	View
Compliance Tasks	View	Manage (assign / reassign)	Execute (own tasks)	View	View
Evidence Review	—	View	Submit only	Review (approve / reject)	View
Learning Management	View (coverage stats)	Manage (assign courses)	Complete (learner)	Complete (learner)	—
Reports	Full	Full	View	Full	Full (export)
Alerts	View	View	View	View	View
User Management	—	Full	—	—	—
Organization Settings	View	Full	View	—	—
Audit Log	View	Full	—	Full	View

The Platform Console is a separate application, accessible only to Super Admin users, with full administrative access to client organization records (excluding their operational data), the shared controls library, the regulation catalog, the LMS course catalog, and the platform-wide audit log.

7. Information Model

NiyamSaathi is organized around a small number of core business entities, consistently linked across every module:

Entity	Description
Organization	A client company using the platform; the top-level container for all its data.
Department	An organizational unit within a client company, used to structure ownership and access.
User	An individual with a role within an organization (or, in the Platform Console, a Super Admin).
Asset	A system, application, vendor, or process that stores or processes data on behalf of the organization.
PII Record	A structured description of the personal data associated with a given asset.
Supplier	A third party linked to one or more assets or departments.
Control	A regulatory or organization-defined requirement, drawn from the shared library or custom-defined.
Assessment	A scoped compliance exercise covering a defined set of assets and controls over a time window.
Compliance Task	An action item linking a control to an asset, assigned to an owner for resolution.
Evidence	A versioned submission demonstrating that a compliance task has been satisfied.
Cloud Connection	A registered link to a client's cloud environment, used for automated asset discovery.
Notification	A system-generated alert delivered to a user in response to a workflow event.
Audit Log Entry	An immutable record of a compliance-relevant action taken within the platform.
Course / Enrollment	A training module in the LMS catalog, and a user's progress against it.

Key relationships:

- An Organization has many Departments, Users, Assets, and Suppliers.
- An Asset may have one or more PII Records describing the personal data it holds.
- An Assessment scopes a set of Assets and Controls, and generates Compliance Tasks.
- Each Compliance Task links one Control and one Asset, and accumulates one or more Evidence submissions over its lifecycle.
- A Cloud Connection produces discovered resources that, once confirmed, become Assets — retaining a link back to their source connection.
- Every state-changing action across these entities is captured as an Audit Log Entry.

8. System Architecture

NiyamSaathi is built as two independently deployed applications — the Tenant Portal and the Platform Console — each backed by its own dedicated application service and database. This separation keeps client-organization data and platform-operator data cleanly segregated at the architectural level.

Within the Tenant Portal, every client organization's data is logically isolated within a shared, multi-tenant data layer, ensuring one organization's data is never accessible to another.

A dedicated cloud-scanning service handles connections into client cloud environments (AWS, Azure, GCP, Microsoft 365, Google Workspace), operating under credentials explicitly granted and encrypted by the client organization, and feeding discovered resources back into the Tenant Portal's asset register for review.

Background processing — such as cloud discovery scans and connection health checks — runs asynchronously, so long-running operations do not block the user experience.

9. Technology Stack

Layer	Technology
Frontend	React-based single-page applications, responsive across desktop and tablet
Backend	Node.js / Express REST APIs
Database	PostgreSQL (managed, dedicated per application)
Background Processing	Asynchronous job queue for scans, integrations, and long-running tasks
Hosting	Microsoft Azure

10. Security & Data Protection

- **Authentication**: Token-based session security using short-lived access tokens with automatic refresh, and industry-standard password hashing.
- **Access control**: Role-based access control enforced at the application and API level for every request, not only in the user interface.
- **Encryption**: Sensitive credentials — including single sign-on secrets and cloud connection credentials — are encrypted at rest.
- **Audit logging**: A complete, immutable record of security- and compliance-relevant events, including logins, evidence submissions, approvals and rejections, and cloud connection activity.
- **Evidence integrity**: A secure, versioned evidence repository that preserves full submission history — evidence is never silently overwritten.
- **Tenant isolation**: Every client organization's operational data is logically segregated within the platform.

11. Integrations

- **Microsoft Entra ID (Azure AD)** — single sign-on and automated group-to-role synchronization for the Tenant Portal.
- **Cloud environment connections** — Amazon Web Services, Microsoft Azure, Google Cloud Platform, Microsoft 365, and Google Workspace, for automated cloud resource discovery.

12. Deployment & Hosting

NiyamSaathi is hosted on Microsoft Azure, with the Tenant Portal and Platform Console deployed as separate, isolated services. Releases are managed through a continuous delivery pipeline, enabling controlled and repeatable deployments.

13. Non-Functional Characteristics

- **Scalability**: Multi-tenant architecture designed to onboard client organizations independently of one another.
- **Extensibility**: The controls and regulation library is structured to accommodate additional regulatory frameworks as client and market needs evolve.
- **Availability**: Hosted on Microsoft Azure's managed cloud infrastructure.

14. Implementation Approach

1. **Organization Onboarding** — profile setup, DPDP classification, organizational structure, and initial team setup.
2. **Asset & Data Register Build-Out** — manual asset registration, supplemented by automated Cloud Discovery for connected environments.
3. **Controls Activation** — activation of the relevant regulatory controls library and initial gap assessment.
4. **Assessment & Evidence Cycles** — scoped assessments, task assignment, evidence submission, and internal audit review.
5. **Ongoing Operation** — continuous monitoring, workforce training via the LMS, and recurring compliance reporting.

15. Platform Roadmap

NiyamSaathi is under active, continuous development. Planned enhancements include:

- Automated evidence and gap-finding generation directly from cloud configuration scan results, further reducing manual evidence collection effort.
- Expanded single sign-on and identity provider support beyond Microsoft Entra ID.
- Additional regulatory frameworks added to the controls library as regulatory guidance evolves.

16. Glossary of Terms

Term	Definition
DPDP Act	The Digital Personal Data Protection Act, 2023 — India's primary data protection law.
Data Fiduciary	An entity that determines the purpose and means of processing personal data.
Significant Data Fiduciary	A Data Fiduciary designated by the government as subject to enhanced obligations, based on factors such as data volume and sensitivity.
Data Principal	The individual to whom personal data relates.
PII	Personally Identifiable Information.
Data Asset	Any system, application, vendor, or process registered in NiyamSaathi that stores or processes data on behalf of an organization.
Control	A specific regulatory or organizational requirement tracked and evidenced within the platform.
Evidence	Documentation submitted to demonstrate that a control or action has been satisfied.
RBAC	Role-Based Access Control.
SSO	Single Sign-On.

End of document.